

Impilo vNext Technical Standards Catalogue

Version 1.0 - Controlled Successor Draft

Status: Supersedes Technical Companion Spec 1.2.0-canonical as a frozen architecture; pending ratification after Target Architecture v1.3.2.

DOCUMENT AUTHORITY

This document is subordinate to the Impilo vNext Hybrid / Federated Target Architecture. Where any conflict exists, the controlling target architecture and its ADRs prevail. This successor draft becomes frozen only after the pending v1.3.2 experience-integrity correction is ratified.

Source lineage: vNext Technical Companion Spec 1.2.0-canonical + Hybrid / Federated Target Architecture v1.3.1.

Contents

1. Catalogue authority and conformance
 2. API and service-contract standard
 3. Identity, session and trusted request-context standard
 4. Event and schema standard
 5. Consistency, offline and reconciliation standard
 6. Clinical record and FHIR standard
 7. Federation protocol standard
 8. Security, audit and support-access standard
 9. Coverage, claims and settlement standard
 10. AI and decision-intelligence standard
 11. Reliability, observability and release standard
 12. Jurisdiction and capability-pack standard
 13. Developer ecosystem and external certification
 14. Conformance gates
- Appendix A. Legacy Technical Companion disposition register
- Appendix B. Canonical contract examples

1. Catalogue authority and conformance

SUPERSESION NOTICE

The former “Impilo vNext v1.2 - Technical Companion Spec, Version 1.2.0-canonical” is superseded as a controlling architecture. Its useful standards are retained here; its client-asserted tenant/pod model, monolithic Tshepo description, password-grant example, pod self-registration and single-Butano truth assumptions are withdrawn.

This catalogue defines reusable technical standards. It does not replace service-specific OpenAPI, AsyncAPI, JSON Schema, FHIR Implementation Guides, Rego policies, database constraints, Helm values or runbooks. Those artefacts are the executable expression of these standards.

Normative term	Meaning
MUST / MUST NOT	Required for conformance; violation blocks release or accreditation.
SHOULD / SHOULD NOT	Expected unless an ADR records a justified exception.
MAY	Permitted within the governing architecture and service profile.
Illustrative contract	A human-readable example; machine-readable source remains authoritative.

2. API and service-contract standard

2.1 API surfaces and lifecycle

- Impilo-native and privileged service APIs use /internal/v{N}/... under a verified service or audience identity.
- Accredited partner, external application and federation APIs use /external/v{N}/... unless a dedicated federation route is defined.
- No breaking change is introduced within a major version. Breaking changes require a new major path, migration plan and deprecation window.
- OpenAPI is generated or validated against implementation and is contract-tested in CI.

2.2 Required non-authority request metadata

Field	Rule
Authorization	Required except for explicitly approved public metadata, health and bootstrap entry points. Audience and assurance must match the operation.
X-Request-ID	UUID; generated at the trusted edge if absent.
X-Correlation-ID	Propagated across calls, events, journeys and support cases.
Idempotency-Key	Required for state-changing commands; same key + same canonical body returns the same outcome; different body returns conflict.
X-Client-Timeout-MS	Internal callers declare remaining budget; services fail fast and propagate bounded time.

NO CLIENT-SUPPLIED AUTHORITY

Browsers, mobile apps and partner clients **MUST NOT** supply load-bearing X-Tenant-ID, X-Pod-ID, X-Facility-ID, X-Actor-ID, X-Provider-ID, purpose or assurance headers. The trusted edge strips such inputs and derives the internal context from verified sessions, work-context tokens, agreements and policy.

2.3 Error contract

```
{
  "error": {
    "code": "STRING_ENUM",
    "message": "Human-readable, non-sensitive explanation",
    "details": { "field": "optional structured detail" },
    "request_id": "uuid",
    "correlation_id": "uuid",
    "retryable": false,
    "remedy": "optional stable remedy key"
  }
}
```

- Errors never expose raw downstream exceptions, stack traces, secrets or clinical payloads.
- EMPTY, UNAVAILABLE, DEGRADED, DENIED and STALE are separate application states, not generic success or generic 500 responses.
- A failure to read cannot be presented as proof that no record exists.

3. Identity, session and trusted request-context standard

3.1 Tshepo trust layer

TSHEPO is the national trust layer, not one service. It encompasses Keycloak identity and authentication, Envoy enforcement, OPA policy, Mvumo consent and delegation, context/session services, credential and federation trust, audit, risk, bundle distribution and related supporting components.

3.2 Authentication and audience

- Interactive web and mobile authentication uses OIDC Authorization Code with PKCE or another approved modern flow.
- Password grant is prohibited for normal user authentication.
- Every session is audience-bound: personal, professional, Work, regulatory, organisation administration, platform administration, node operations or break-glass.
- A national session is never handed to a node. A node independently validates eligibility and mints its own Work session.
- Step-up authentication is explicit and action-bound; institutional OIDC/SAML may be federated where accredited.

3.3 Trusted internal request context

```
{
  "context_version": 1,
  "trust_domain_id": "uuid",
  "organisation_id": "uuid|null",
  "facility_id": "uuid|null",
  "node_id": "uuid|null",
  "actor_health_id": "uuid",
  "provider_id": "string|null",
  "work_context_id": "uuid|null",
  "audience": "impilo-work:NODE-PARI-01",
  "purpose_of_use": "CLINICAL_CARE",
  "assurance_level": "AAL2",
  "device_posture": "MANAGED_SHARED",
  "issued_at": "RFC3339",
  "expires_at": "RFC3339",
}
```

```
"issuer": "tshepo-context",
"signature": "detached-or-token-bound"
}
```

- Context is derived server-side and cryptographically bound to the verified session or service identity.
- Services reject missing, expired, mismatched or audience-incompatible context.
- node_id is provenance and routing metadata; it is never a clinical business-ownership predicate.
- One request has one active work context. Separate sessions may coexist only under the governed concurrency policy.

4. Event and schema standard

4.1 Topic naming and ownership

```
impilo.{owner}.{domain}.{entity}.{action}.v{N}
```

- Every topic has one owning domain team and a partitioning decision record.
- Kafka is an intra-node event bus. Cross-site federation uses signed gateway envelopes, not raw topics.
- Schema registry compatibility is backward-compatible by default; breaking changes require a new major event and migration plan.

4.2 Canonical event envelope

```
{
  "event_id": "uuid",
  "event_type": "impilo.pct.encounter.updated.v1",
  "schema_version": 1,
  "correlation_id": "uuid",
  "causation_id": "uuid|null",
  "idempotency_key": "string",
  "producer": "service-name",
  "trust_domain_id": "uuid",
  "origin_node_id": "uuid|null",
  "organisation_id": "uuid|null",
  "facility_id": "uuid|null",
  "subject_type": "encounter",
  "subject_id": "id",
  "origin_record_id": "id|null",
  "record_version": 7,
  "occurred_at": "RFC3339",
  "emitted_at": "RFC3339",
  "actor": { "health_id": "uuid|null", "provider_id": "string|null", "work_context_id": "uuid|null" },
  "payload": { "op": "UPDATE", "before": {}, "after": {}, "changed_fields": [] },
  "meta": { "partition_key": "...", "purpose_of_use": "...", "policy_version": "..." },
  "signature": "optional/required by transport profile"
}
```

Financial events additionally carry authoritative financial references, amount, currency and lifecycle state. AI-linked events additionally carry model, version, inference class and human-review requirement. Clinical federation records carry provenance and amendment semantics defined by the Target Architecture.

4.3 Delta, snapshot and replay

- Delta events are the default for ordinary change propagation.
- Snapshots support new consumers, recovery, backfill and approved projection rebuilds.
- Consumers are idempotent, replay-safe and able to quarantine poison messages.
- Every projection publishes freshness and replay watermarks.

4.4 Partitioning decision record

1. Topic and owner
2. Partition key and ordering guarantee
3. Expected volume and consumers
4. Hot-partition risk
5. Replay/bootstrap implications
6. Repartitioning migration plan

5. Consistency, offline and reconciliation standard

5.1 Clinical action classes

Class	Meaning	Authoritative proof
A - Current hard truth	High-risk action requiring a current decision	Node-local or national authoritative source, current signed bundle, valid offline instrument or live national truth according to the domain
B - Bounded stale	Routine action may use a projection within a declared ceiling	Freshness watermark, evidence log and reconciliation path
C - Offline permitted	Explicitly allowed care action continues while disconnected	Valid local authority, offline entitlement where required, local audit and post-reconnection reconciliation

LOCAL CARE RULE

Class A does not mean “call the National Core synchronously.” It means obtain a current authoritative decision from the appropriate recognised trust source. Routine Hospital Node care has no synchronous National Core dependency.

5.2 Authority and content freshness

- Content age and authority age are separate clocks and are displayed separately where clinically relevant.
- Staleness can narrow permitted actions but never widen them.
- A remote revocation cannot be enforced before it is received; local and previously received revocations apply immediately.
- Past the authority ceiling, affected classes fail closed except explicitly governed emergency minimums.

5.3 Reconciliation

- Every offline-capable command defines idempotency, conflict detection, amendment or compensation, ordering and user-visible status.
- Clinical facts are amended or superseded; cross-node last-write-wins is prohibited.
- Financial actions define reversal, refund, recovery and reconciliation before release.
- Reconnect processing is durable, observable and quarantine-capable.

6. Clinical record and FHIR standard

FHIR remains the governed representation for longitudinal clinical resources. It does not create one globally writable clinical database. Record authority is origin-bound and projections preserve provenance.

Record concept	Technical rule
Facility Operational Record	Authoritative operational record for care delivered by the

Record concept	Technical rule
	facility/node; includes workflow state that does not belong in national longitudinal memory.
Node Butano projection	Governed node-local FHIR projection of local clinical facts, origin-stamped and amendment-aware.
National Butano projection	National longitudinal projection assembled through federation; never overwrites the origin.
Personal Health Record	Individual national product with provenance classes, consent and user-contributed information.
Shared-Care Cache	Cohort-scoped continuity projection, separate from Node Butano, with content and authority freshness.

- Canonical FHIR profiles and validation are governed with ZIBO terminology and versioned implementation guides.
- UI state, queues, temporary drafts, claim adjudication and settlement state do not become hidden FHIR systems of record.
- Large documents and DICOM objects follow governed metadata and on-demand retrieval profiles rather than bulk replication.

7. Federation protocol standard

7.1 Institutional and node onboarding

1. Organisation and authorised officer are verified.
2. Facilities are claimed, legitimate and linked to the governing organisation.
3. Service agreement, trust domain and per-domain authority assignments are approved.
4. Node Administrator is appointed without receiving clinical or application roles.
5. Bootstrap Manifest is issued and the signed Bootstrap Agent enrolls infrastructure.
6. Fleet Service registers node identity, certificates, capabilities and release state.
7. Conformance, backup/restore, disconnection and support-audit tests pass.
8. Organisation officer countersigns activation.

A node never grants itself legal, clinical or disclosure authority by requesting it in a registration payload. Authority originates in governance records and agreements.

7.2 Transport and identity

- Federation Gateway is the only sanctioned cross-site application path.
- Mutual TLS, certificate-bound node identity, signed envelopes and schema compatibility are mandatory.
- node_id is verified against certificate and Fleet state; trust_domain_id is obtained from the accredited node record, not client text.
- Durable queues exist at both ends; acknowledgements, retries, replay and quarantine are explicit.
- No database replication and no raw Kafka exchange across institutions.

7.3 Authority, merges and revocation

- Every domain declares national authority, origin authority, local authority or projection status in the governing agreement.
- National identity merges publish mappings and reconciliation instructions; they do not destructively overwrite origin records.
- Consent, provider standing, certificates and agreement revocations use high-priority control bundles and auditable application.

- Conflicts are classified; unresolved integrity or schema failures quarantine exchange without stopping local care.

8. Security, audit and support-access standard

- Envoy policy enforcement and OPA/PDP decisions are active on the real request path; shadow mode is not conformance.
- Platform administration, node operations, organisation administration and clinical access are separate audiences and roles.
- Data-bearing support access is case-bound, time-boxed, purpose-bound and recorded; it is never standing.
- Support-session evidence is dual-written to the Tshepo Assurance Sink and an institution-nominated external sink. If the independent sink is unavailable, data-bearing access does not proceed.
- Encryption profiles state the exact protection layer, key custody, KMS/HSM placement, runtime limitations, backup behaviour and restore authorisation.
- Managed hosting does not claim cryptographic impossibility of operator runtime access unless attestation, confidential computing, external KMS/HSM and external audit are all implemented.

9. Coverage, claims and settlement standard

Class	Examples	Required behaviour
F1 - Immediate hard truth	Eligibility commitment, guarantee, reservation, final instant approval, settlement, reversal	Authoritative synchronous or governed signed proof; idempotent and auditable
F2 - Near-real-time	Preauthorisation triage, provisional adjudication, quote validation, remittance preparation	Bounded lag; recheck before irreversible action
F3 - Deferred/batch	Invoicing, actuarial runs, payment batching, reconciliation	Asynchronous, replay-safe and fully reconciled

Minimum lifecycle support includes initiated, eligibility verified, preauthorised, reserved, provisionally adjudicated, approved, remitted, paid, settled, reversed, reconciled, disputed and recovered. Every transition has an idempotency key, actor, basis, financial reference and compensation path.

10. AI and decision-intelligence standard

- Every model is registered, versioned, approved for named use cases and withdrawable.
- Inference records include model/version, input-context class, timestamp, confidence or score where relevant, human-review requirement and final human action.
- Nompilo may explain, recommend, navigate, summarise and visibly prefill. It has no transactional route to submit, consent, disclose, prescribe, approve or change authority.
- Prompt instructions are not the safety boundary; endpoint reachability and policy are.
- Monitoring covers performance, drift, bias where applicable, safety events, overrides and rollback.

11. Reliability, observability and release standard

Area	Required standard
SLOs	Availability, latency, freshness, error budget and capacity per service/profile.
Golden signals	Traffic, latency, errors and saturation, plus projection lag, queue age, audit success, settlement/reconciliation and model-

Area	Required standard
	health metrics.
Persistence	No critical database, identity store, object store, broker, PACS or audit chain may depend on ephemeral storage.
Backup and DR	Automated backup, restore drills, declared RPO/RTO, reconciliation and data-disposition procedures.
Release	Signed artefacts, compatibility floors, progressive delivery, controlled windows, rollback and Fleet evidence.
Schedulers	Distributed locking or leader election for singleton jobs.
Build integrity	Clean worktree and reproducible build context; runtime-configurable endpoints are not baked to localhost.

12. Jurisdiction and capability-pack standard

- Packs are signed, versioned, auditable artefacts with declared platform and schema compatibility.
- They may enable modules, role maps, workflows, checklists, forms, geography, dashboards, documents, SLA/escalation and legal-reference metadata.
- They may not redefine canonical identifiers, bypass audience boundaries, weaken security floors or break contracts.
- Pack behaviour is tested in CI and field-validated where it changes user or operational journeys.
- A new standalone service requires an ADR demonstrating that configuration and shared domain objects are insufficient.

13. Developer ecosystem and external certification

- Developer portal with current contracts, SDKs, sandbox, credentials, examples and deprecation notices.
- Registration and certification for third-party apps, institutional systems, payers, analytics and AI consumers.
- Contract test packs and synthetic conformance environments.
- Explicit scopes, purposes, rate limits, audit obligations, incident reporting and revocation procedures.
- No external client receives internal trusted-context authority merely by sending headers.

14. Conformance gates

1. No browser- or handset-supplied authority is load-bearing.
2. Policy enforcement is active on the actual request path.
3. Web and mobile consume the same experience decisions.
4. Node-local care works through the declared autonomy window without a National Core call.
5. Federation envelopes preserve origin, version, authority and signature.
6. Events are schema-registered, partitioned by an explicit decision and replay-safe.
7. Clinical and financial action classes are enforced and evidenced.
8. Support access, backup, restore, pod exec, logs, secrets and object stores are tested at the infrastructure layer.
9. Accessibility, localisation, shared-workstation privacy and field usability are proven before production declaration.
10. One external integration and one complete care-to-settlement steel thread pass current certification.

Appendix A. Legacy Technical Companion disposition register

Legacy section	Disposition	Successor treatment
Global A - Base URL/versioning	RETAIN / AMEND	Retain internal/external and versioning; machine-readable OpenAPI is authoritative.
Global B - Tenant/pod headers	SUPERSEDE	Replace client-supplied X-Tenant-ID/X-Pod-ID with server-derived signed request context.
Global C - Error response	RETAIN / EXPAND	Retain structure; add retryability/remedy and prohibit raw exceptions.
Global D - Idempotency	RETAIN	Binding for state-changing commands; conflict on same key/different canonical body.
Global E - Timeouts	RETAIN	Propagate bounded remaining budget.
Global F-I operational/financial/AI rules	RETAIN / MOVE	Remain cross-platform standards.
1.1 TSHEPO service	SUPERSEDE / DECOMPOSE	Tshepo is a trust layer; endpoints belong to named components.
1.1.1 password token example	REMOVE	Use OIDC code + PKCE and audience-bound sessions.
1.1.2 PDP decision	RETAIN / AMEND	Retain decision contract; use trusted server-derived context and node-local decision where appropriate.
1.1.3 offline entitlement	RETAIN / NARROW	Valid pattern for devices/edge/specific scopes, not the whole Hospital Node offline architecture.
VITO / VARAPI / TUSO / INDAWO / MSIKA	RETAIN / UPDATE	Retain ownership; align identifiers, trust domains, provenance and current APIs.
BUTANO canonical truth	SUPERSEDE	Replace one writable truth with origin authority plus node/national projections, PHR and Shared-Care Cache.
MUSHEX and coverage contracts	RETAIN / MOVE	Standards retained; exact endpoints move to service OpenAPI/domain specifications.
Eventing standard	RETAIN / AMEND	Replace tenant/pod envelope with trust-domain/origin metadata; raw cross-site Kafka prohibited.
Consistency classes	RETAIN / AMEND	Authoritative proof may be node-local, bundle-based, offline instrument or national.
Infrastructure blueprint	MOVE / AMEND	Norms retained; deployment profiles and BOM governed by Target Architecture.
Pod registration handshake	SUPERSEDE	Replace self-registration with institutional commissioning, Bootstrap Manifest, Fleet and countersignature.
Federation auth/conflict	RETAIN / AMEND	mTLS and signed identity retained; authority comes from accredited records and agreements.
Production gates	RETAIN / EXPAND	Align to current acceptance suite and experience/usability gates.

Appendix B. Canonical contract examples

B.1 Structured denial

```
HTTP 403
{
  "error": {
    "code": "POLICY_DENY",
    "message": "This action is not available in the current work context.",
    "details": { "required_audience": "impilo-professional" },
    "request_id": "...",
    "correlation_id": "...",
    "retryable": false,
    "remedy": "OPEN_PROFESSIONAL_DOMAIN"
  }
}
```

B.2 Federation authority violation

```
HTTP 403
{
  "error": {
    "code": "FEDERATION_AUTHORITY_VIOLATION",
    "message": "The origin is not authorised to amend this national-authoritative field.",
    "details": {
      "data_domain": "identity.national_identifier",
      "origin_node_id": "NODE-X",
      "authority_rule": "NATIONAL_ONLY"
    },
    "request_id": "...",
    "correlation_id": "...",
    "retryable": false
  }
}
```